Cloud Incident Response Playbook

Azure subscription "Azure subscription 1" · Entra ID tenant · EHR ePHI storage

Owner: Sabitha S Karanavar, Security & Risk Lead · Approved: Medical Director · Effective 15 October 2026 · Review: every 6 months and after every SEV1/SEV2

1. Purpose, scope and authority

This playbook tells HVMC staff exactly what to do when a security event is detected in the Azure environment that hosts the EHR storage (ePHI), the three-tier network and the Entra ID identities. It satisfies the HIPAA Security Rule requirement for security incident procedures (45 CFR §164.308(a)(6)) and feeds the Breach Notification Rule (§164.400-414). It follows the incident response lifecycle of **NIST SP 800-61 Rev. 3** (aligned to CSF 2.0 Detect, Respond and Recover), expressed as five phases: identification, containment, investigation, eradication and recovery, followed by lessons learned.

In scope: subscription HVMC-CloudSecurity-RG resources, Entra ID accounts and roles, the ePHI storage account, and the security tooling (HVMC-SecOps-LAW, Defender for Cloud, Sentinel). **Detection sources:** 9 Azure Monitor alert rules (e-mail), 4 custom Sentinel analytics rules + Fusion + Defender incident creation, Defender for Cloud alerts (e-mail).

2. Roles and responsibilities

Role	Assigned to	Responsibilities
Incident Commander (IC)	Security & Risk Lead — Sabitha S Karanavar	Declares the incident and severity, owns the timeline, approves containment, closes the incident
Cloud Operations Responder	IT Manager / Azure administrator	Executes containment and recovery changes in Azure; preserves configuration evidence
Investigator / Analyst	Security analyst (rota)	Runs KQL and Sentinel investigation, builds the timeline, scopes affected ePHI
Privacy Officer	Interim: Compliance Manager (R16 — post vacant)	Runs the HIPAA breach risk assessment (4 factors) and notifications
Communications & Legal	Practice Administrator + outside counsel	Staff, patient, regulator and media communication; law-enforcement liaison
Executive sponsor	Medical Director	Business decisions (e.g. take EHR offline), funding, board briefing

Activity	IC	Cloud Ops	Analyst	Privacy	Comms	Exec
Triage and severity	A	C	R	I	–	I (SEV1-2)
Containment action	A	R	C	I	–	C (SEV1)
Investigation / scoping	A	C	R	C	–	–
Eradication and recovery	A	R	C	–	–	I
HIPAA breach assessment	C	–	C	A/R	C	I
External notification	C	–	–	R	R	A

Lessons learned	A/R	C	C	C	C	I

R = responsible, A = accountable, C = consulted, I = informed. HVMC is small, so one person may hold several roles; the Incident Commander must never approve their own containment change on a SEV1.

3. Severity and response targets

Severity	Examples	Acknowledge	Contain	Escalation
SEV1 Critical	Confirmed ePHI access/exfiltration, ransomware, Global Admin compromise	15 min	1 h	Phone bridge; Exec + Privacy within 1 h
SEV2 High	Internet exposure of a tier, privileged role misuse, logging disabled, malware in ePHI store	30 min	4 h	IC + CloudOps; Exec informed same day
SEV3 Medium	Suspicious key/credential use, unapproved config change, Defender Medium alert	4 h	1 business day	Ticket; IC review
SEV4 Low	Policy deviation, benign-positive alert, informational finding	1 business day	5 business days	Ticket only

HIPAA: any incident where ePHI may have been accessed by an unauthorised person goes to the Privacy Officer, who runs the four-factor breach risk assessment (nature of the PHI, who received it, whether it was actually viewed, mitigation). If a breach is confirmed: notify patients without unreasonable delay and within 60 days; notify HHS (within 60 days if 500 or more patients, otherwise in the annual log) and prominent media if 500 or more residents of a state are affected.

4. Common procedure for every incident

Phase	What to do
1 Identification	Detect and validate. Sources: Azure Monitor alert e-mail, Sentinel incident, Defender alert, user report. Acknowledge in Sentinel (owner + status Active), assign severity, open the incident record, start the timeline (UTC).
2 Containment	Stop the harm while preserving evidence. Short-term: block, revoke, isolate. Take configuration snapshots before changing anything. Decision rule: contain first for SEV1/2, investigate first for SEV3/4.
3 Investigation	Who, what, when, where, how — Activity Log, resource logs, flow logs and Sentinel entity pages. Determine scope (resources, identities, ePHI records). Hash and store exported evidence.
4 Eradication	Remove the cause: misconfiguration, malicious artefact, persistence (extra role assignments, keys, apps). Sweep the whole subscription for the same weakness.
5 Recovery	Restore service and the secure baseline, verify with the change detector / config diff, monitor closely for 72 h, close the incident with classification, hold a lessons-learned review within 5 business days.

Evidence handling: export queries and configuration snapshots as JSON, record the SHA-256 of each file, and store them in the incident folder with the time, collector and source; never edit originals. All times are UTC.

5. Scenario playbooks

PB-01 — Internet exposure / unauthorised firewall change

Default severity	SEV2
Risks treated	R03, R10
MITRE ATT&CK	T1190 Exploit public-facing application (enabler); T1562 Impair defences
Triggers	Alert HVMC-NSG-Rule-Changed / -Deleted / HVMC-Public-IP-Created; Sentinel 'NSG inbound rule opened to the Internet'
Tested	Live test 15 Oct 2026 (section 6)

1 Identification	1. Open the alert e-mail / Sentinel incident; note rule, NSG, caller, caller IP, time. 2. Check the change calendar: is there an approved change (IP-1)? If yes → SEV4 benign, go to Recovery. 3. If no approval and the rule allows Internet inbound → SEV2.
2 Containment	1. Snapshot the NSG: az network nsg show -g HVMC-CloudSecurity-RG -n <nsg> > nsg_before.json 2. Remove or disable the offending rule (or add a higher-priority Deny) — IC approval. 3. If a public IP was attached, disassociate it.
3 Investigation	1. KQL: AzureActivity | where _ResourceId has '<rule>' | project TimeGenerated, Caller, CallerIpAddress, OperationNameValue 2. Everything else the caller did ±24 h; was the account compromised (Entra sign-in history)? 3. Flow logs: any inbound flows from the Internet to the tier while the rule existed?
4 Eradication	1. Sweep all NSGs for Internet-facing allow rules (only Web 443 is approved). 2. If the caller was compromised: run PB-02 for the identity.
5 Recovery	1. Diff NSGs against the baseline snapshot; confirm App→Data 1433 still works. 2. Close incident with classification; update the change record and the risk register (R03).

PB-02 — Privilege escalation / privileged role misuse

Default severity	SEV2 (SEV1 if Global Admin)
Risks treated	R04, R07
MITRE ATT&CK	T1098 Account manipulation; T1078 Valid accounts
Triggers	Alert HVMC-Role-Assignment-Added; Sentinel 'Privileged Azure role assigned'; Defender for Resource Manager alerts
Tested	Tabletop exercise 15 Oct 2026 (section 7)

1 Identification	1. Record principal, role, scope, caller and time from the incident entities. 2. Check for an approved access request (IP-2). Microsoft service principals created by an approved change are benign.
2 Containment	1. Remove the role assignment (az role assignment delete --ids <id>). 2. Revoke the principal's sessions (Microsoft Graph revokeSignInSessions) and block sign-in if compromise is suspected. 3. If the caller is a human admin account, reset its credentials and require MFA re-registration.
3 Investigation	1. KQL: AzureActivity | where Caller == '<principal>' — every action taken with the new rights. 2. List all assignments of the principal across scopes; review Entra audit history. 3. Did the principal read storage keys or ePHI (StorageBlobLogs)? If yes → Privacy Officer (HIPAA assessment).
4 Eradication	1. Remove persistence: extra role assignments, app registrations, secrets, federated credentials. 2. Sweep: no Owner / Contributor / UAA for non-admin users at subscription or resource-group scope.
5 Recovery	1. Re-enable the account only after credential reset and manager confirmation. 2. Confirm role list equals the access baseline; close incident; lessons learned (R04 two-admin control).

PB-03 — ePHI storage threat (Defender for Storage alert / malware / key misuse)

Default severity	SEV2 (SEV1 if exfiltration confirmed)
Risks treated	R02, R05, R11
MITRE ATT&CK	T1530 Data from cloud storage; T1552 Unsecured credentials; T1105 Ingress tool transfer
Triggers	Defender for Storage alerts (malware upload, unusual access, anomalous extraction); HVMC-Storage-Keys-Listed; Sentinel 'ePHI storage keys retrieved'
Tested	Live test 15 Oct 2026 (section 6)

1 Identification	1. Acknowledge the Defender alert (status In progress) and the Sentinel incident. 2. Read the alert entities: storage account, container/blob, client IP, user agent, authentication type.
2 Containment	1. Rotate the access key the alert implicates (or both, one at a time) — copied keys stop working. 2. Revoke SAS by rotating the signing key; if malware, the blob is quarantined/deleted via the scan result tag. 3. If active exfiltration: set the storage firewall default action to Deny (IC + Exec decision, EHR impact).
3 Investigation	1. StorageBlobLogs: operations, caller IPs and objects read by the suspicious client. 2. Count ePHI records/patients in the objects accessed — input to the HIPAA 4-factor assessment. 3. AzureActivity: who listed or regenerated keys.
4 Eradication	1. Confirm malware scanning and Defender for Storage remain enabled; remove malicious blobs. 2. Remove any unknown SAS policies, CORS rules or network exceptions.
5 Recovery	1. Resolve Defender alerts; restore deleted data from versioning / soft delete if needed (R05). 2. Privacy Officer decides on breach notification (≤ 60 days, HHS, media if > 500 patients).

PB-04 — Security logging disabled or tampered (defence evasion)

Default severity	SEV2
Risks treated	R01
MITRE ATT&CK	T1562.008 Disable or modify cloud logs
Triggers	Alert HVMC-Diagnostic-Setting-Deleted; Sentinel 'Security logging disabled or deleted'; dashboard coverage < 100 %; ingestion drops to 0
Tested	Not yet tested — scheduled Phase 2

1 Identification	1. Confirm which log source stopped (dashboard coverage table / Usage table). 2. Treat as an attacker covering tracks until proven otherwise.
2 Containment	1. Re-run scripts/01_setup_logging_alerting.sh to restore the diagnostic setting / flow log (idempotent). 2. Suspend the caller's privileged access pending review (PB-02 containment).
3 Investigation	1. The Activity Log keeps 90 days even when the export is deleted: query it with az monitor activity-log list. 2. Identify the logging gap window and what happened inside it.
4 Eradication	1. Apply a resource lock / Azure Policy (deployIfNotExists) so diagnostic settings are re-created automatically.
5 Recovery	1. Verify every source is reporting (dashboard 100 %), back-fill the timeline, close incident.

6. Live playbook tests — exercise HVMC-IRX-2026-10

Two playbooks were exercised live on 15 October 2026 with safe, controlled triggers, so no security control was weakened at any point: **PB-03** used Microsoft Defender for Cloud's built-in sample alerts for Storage, and **PB-01** used a real, approved hardening change (an explicit Deny-Internet-inbound rule on the Data-tier NSG, which also treats risk R03). The script `scripts/ir_tests.py` drove each phase and recorded timestamps; raw results are in `evidence/ir_tests/`.

Test	Scenario	Injected (UTC)	Detected	Time to detect (min)	Detect → recovered (min)	Phases passed
PB-01	Unplanned firewall change on the Data tier - detection and change verification	18:00:49	18:07:26	6.6	0.3	**4/4**
PB-03	ePHI storage threat - Defender for Storage alerts (built-in sample alerts)	18:03:31	18:03:32	0.0	4.7	**6/6**

PB-01 timeline

Phase	Start	End	Result	Evidence
1 Identification	18:00:52	18:07:39	**Pass**	Azure Monitor alert HVMC-NSG-Rule-Changed fired at 2026-10-15T18:07:26Z; e-mail sent to the Security Lead
2-3 Triage, containment decision and investigation	18:07:39	18:07:41	**Pass**	who: sabithaskaranavar@gmail.com; what: Inbound Deny from Internet to port *; matches approved change HVMC-CHG-04 -> authorised; effect reduces exposure
4 Eradication (exposure sweep)	18:07:41	18:07:44	**Pass**	sweep of all NSGs: no Internet-facing allow rule except the approved Web HTTPS 443 rule
5 Recovery (baseline updated)	18:07:44	18:07:45	**Pass**	baseline updated with the approved change; difference from previous baseline: ['Deny-Internet-Inbound-Data p4000 Deny Internet->*']; App->Data 1433 rule unchanged

PB-03 timeline

Phase	Start	End	Result	Evidence
1 Identification	18:03:32	18:07:24	**Pass**	26 Defender alerts: [SAMPLE ALERT] Access from a Tor exit node to a storage blob container; [SAMPLE ALERT] Access from a Tor exit node to a storage file share; [SAMPLE ALERT] Access from a suspicious IP to a storage blob container; [SAMPLE ALERT] Access from a suspicious IP to a storage file share; [SAMPLE ALERT] Access from an unusual location to a storage blob container; [SAMPLE ALERT] Access from an unusual locati
1b Triage / acknowledge	18:07:24	18:07:48	**Pass**	26 alerts set to In progress (acknowledged)
2 Containment	18:07:48	18:07:50	**Pass**	secondary access key of hvmcehrstorage regenerated (key2 not used by any application); network posture recorded: {'defaultAction': 'Allow', 'publicNetworkAccess': 'Enabled', 'sharedKey': True}
3 Investigation	18:07:50	18:07:52	**Pass**	alert entities reviewed; ePHI blob data-plane operations in 24 h: 0; control-plane events on the account in 24 h: 0 (all by known callers)
4 Eradication	18:07:52	18:07:52	**Pass**	Defender for Storage Standard and malware scanning True confirmed; sample alerts carry no payload, so no blob needed removal

5 Recovery	18:07:52	18:08:15	**Pass**	26 Defender alerts resolved; protection verified still enabled

Microsoft Sentinel incidents (15 Oct 2026)

#	Title	Severity	Created	Closed	Minutes open	Classification
#1	HVMC - Privileged Azure role assigned (Owner / Contributor / User Access Administrator)	High	17:17:18	18:14:21	57.0	BenignPositive / SuspiciousButExpected
#2	HVMC - Privileged Azure role assigned (Owner / Contributor / User Access Administrator)	High	17:22:19	18:14:18	52.0	BenignPositive / SuspiciousButExpected
#3	HVMC - NSG inbound rule opened to the Internet	High	18:12:22	18:14:15	1.9	FalsePositive / IncorrectAlertLogic
#4	HVMC - NSG rule change on hvmc-data-nsg: rule body not logged - verify access and direction	Medium	18:15:05	18:15:39	0.6	BenignPositive / SuspiciousButExpected
#5	HVMC - ePHI storage keys retrieved or storage exposure changed	Medium	18:17:30	18:44:16	26.8	BenignPositive / SuspiciousButExpected
#6	HVMC - NSG rule change on hvmc-data-nsg: rule body not logged - verify access and direction	Medium	18:20:07	18:44:13	24.1	BenignPositive / SuspiciousButExpected
#7	HVMC - ePHI storage keys retrieved or storage exposure changed	Medium	18:22:36	18:44:10	21.6	BenignPositive / SuspiciousButExpected
#8	HVMC - ePHI storage keys retrieved or storage exposure changed	Medium	18:27:35	18:44:06	16.5	BenignPositive / SuspiciousButExpected

What the tests found

Finding	Evidence	Action taken / planned
Detection works end to end	PB-01: NSG change alert e-mailed 6.6 min after the change; PB-03: Defender alerts in Sentinel's SecurityAlert table 6 s after the trigger	None - meets the SEV2 acknowledge target (30 min).
False positive: hardening change raised a High incident	Incident #3 'NSG inbound rule opened to the Internet' for the DENY rule; the Activity Log event had no request body	Done 18:14 UTC: rule tuned to compute severity per event (High only for a logged Internet ALLOW, Medium 'verify' otherwise). Re-run produced incident #4 at Medium - verified and closed.
Defender alerts did not become Sentinel incidents	26 alerts reached SecurityAlert, but the 'Create incidents from Defender for Cloud alerts' rule produced none	Planned: add a scheduled rule on SecurityAlert (ProductName == 'Azure Security Center') as a fallback; check the connector after 24 h.
Duplicate incidents for one event	One NSG write produced incidents #4 and #6; one key regeneration produced #5, #7 and #8 - each rule looks back 15 min every 5 min with no grouping	Done 18:43 UTC: incident grouping (all entities, 5 h look-back) enabled on all four scheduled rules; #5-#8 closed as duplicates of verified events. Workbook showed 4 'New' incidents before triage, 0 after.
Alert fatigue	HVMC-Defender-Security-Alert sent one e-mail per Defender alert (26 e-mails in 4 min)	Planned: route Defender alerts only through the security contact (Medium+) and Sentinel; reduce the activity-log rule to High severity.

Real detections of platform changes	Incidents #1-#2: User Access Administrator granted to the Sentinel service principal during onboarding	Closed Benign Positive; lesson: pre-register planned changes (change ID + window) in a Sentinel watchlist.
Tooling defects found and fixed	Wrong Defender alert API region (first PB-03 attempt failed safely before any change); incident close used a stale etag after commenting	Both fixed in scripts/ir_tests.py; incidents closed with scripts/close_incidents.py.

7. Tabletop exercise — PB-02 privilege escalation

Date / duration	15 Oct 2026 · 45 min
Facilitator	Sabitha S Karanavar (Incident Commander)
Participants	IT Manager (Cloud Ops), Security analyst, Compliance Manager (interim Privacy Officer) — roles played by the author
Scenario	17:12 UTC: eight HVMC-Role-Assignment-Added alerts arrive within one second, one for User Access Administrator. Real data from 15 Oct 2026 is used as the inject; facilitator then adds a variant in which the same role is granted to the clinical test account 'Test Nurse - EHR'.

Time	Inject	Response	Phase	Time taken
T+0	Eight role-assignment alerts e-mailed	Analyst opens the alerts; IC declares a potential SEV2 and opens the timeline.	Identification	3 min
T+5	Entities: three Microsoft service principals; caller is the Global Admin; time matches change HVMC-CHG-02 (Defender/Sentinel enablement)	Analyst verifies principal names and scopes with az role assignment list; IC classifies benign — platform-managed identities.	Identification / triage	6 min
T+15	Variant: User Access Administrator granted to 'Test Nurse - EHR' at resource-group scope, no access request	IC raises SEV2. CloudOps would delete the assignment, revoke sessions and block sign-in (commands rehearsed, not executed).	Containment	4 min to decision
T+25	Did the account use the role?	Analyst runs the PB-02 KQL for Caller == test account: no operations; StorageBlobLogs: no ePHI access → no HIPAA notification.	Investigation	8 min
T+35	Persistence check	Sweep for other privileged assignments to users and new app registrations: none found.	Eradication	5 min
T+40	Recovery	Account re-enabled only after password reset and manager confirmation; access baseline diff clean; incident closed.	Recovery	5 min

Findings

- Platform service-principal assignments look identical to an attack in the alert e-mail — add the principal display name and role to the alert (Sentinel rule already does; Azure Monitor alert does not).
- No documented approver for emergency role removal at night — single Global Admin (R04) is also the only person able to contain.
- Revoking sessions requires Graph permissions held only by the Global Admin — create a break-glass procedure.
- Pre-registering planned changes (change ID + time window) would allow automatic benign closure.

8. Lessons learned and improvement actions

Action	Owner	Due	Improves
Fallback Sentinel rule on SecurityAlert so Defender alerts always create incidents (test finding)	Analyst	Oct 2026	PB-03 coverage
Limit Defender e-mails to one channel; HVMC-Defender-Security-Alert only for High (test finding)	CloudOps	Oct 2026	Alert fatigue

Add an automation rule that assigns owner and severity tags to new incidents	IC	Nov 2026	MTTA
Second Global Administrator + break-glass account (R04)	Exec / IC	Oct 24 2026	Containment out of hours
Enrich Azure Monitor alert e-mails (principal, role, rule body) via the common alert schema in a Logic App	CloudOps	Phase 2	Triage time
Change calendar feed into Sentinel watchlist for automatic benign classification	Analyst	Phase 2	Alert fatigue
Azure Policy deployIfNotExists for diagnostic settings (PB-04 eradication)	CloudOps	Phase 2	R01
Entra ID P1 trial to stream sign-in logs (closes the coverage gap, R12)	IC	Phase 2	Coverage 11/11